Описание находки: — 2–3 предложения: что проверяет шаблон и что утверждает находка. Своими словами.
Вердикт: — подтверждено или не подтверждено.
Обоснование:— 2–4 предложения со ссылкой на конкретные данные из артефактов. Утверждения без опоры на факт не засчитываются.
Severity: — если подтверждено, оцените критичность (info / low / medium / high / critical) и поясните выбор одной фразой.

Часть 1

Кейс 1

Описание находки: шаблон фаззит стандартные пути, анализируя ответы сервера. сканер утверждает, что присутствует утечка конфига php через шаблонную страницу mamp, которая оказалась в общем доступе.
Вердикт: относительно не подтверждено
Обоснование: сама страничка особого интереса не представляет - стандартный шаблон мамп с инструкцией (вывод модулей , переменных окружения, расширений, версии интерпретатора на страницу /Applications/MAMP/htdocs/phpinfo.php). но с другой стороны, сама доступность этой страницы раскрывает стек (php, mamp) и прямо указывает на шаблонные пути в данном окружении (что тоже является проблемой, если разработчики оставили стандартные)
Severity: low. раскрытие стека и, вероятно, путей (при стандартной настройке), без деталей

Кейс 2

Описание находки: сканер проверяет на наличие open redirect'a в системе sso. подставляет канарейку в параметр, отвечающий за то, куда пользователя перекинет после авторизации. проверяет на то, фильтруется ли параметр return и сможет ли злоумышленник воспользоваться этим для фишинга/кражи токена авторизации
Вердикт: неопределенно
Обоснование: в артефактах проведена проверка только пре-редиректа. можно увидеть, что параметр /k3mq7x.interact.sh отображается в ответах сервера, но утверждать, что сайт действительно редиректит - нельзя, тк пока редирект отображается только как переменная (стоил в url легитимного домена после "?"). единственный момент - сервер не выдал ошибку моментально, что настораживает, но без запроса на `/Shibboleth.sso/Logout/?return=https://k3mq7x.interact.sh` (с последующей проверкой параметра Location и HTTP-хитов) ничего утверждать нельзя
Severity: если подтвердится - medium.

Кейс 3

Описание находки: сканер фаззит стандартные пути. нашел оказавшийся в открытом доступе файл с конфигами wp
Вердикт: — подтверждено.
Обоснование:— найден файл /.wp-env.json, раскрывающий стек, версии php и wp, маппинги и загруженные плагины. также раскрываются внутренние пути (стейдж) и включенный дебаг
Severity: — low. напрямую не проэксплуатировать при корректной настройке компонентов, но данный файл дает злоумышленнику карту сайта и возможность целеноправлено подбирать эксплойты. критичность также зависит от того, есть ли из внешней сети доступ к стейджу и что отдает сервер при включенном дебаге

Часть 2

gidromash-service.ru
Что это такое — 1–2 предложения: что за объект и откуда он взялся.
Вердикт — одно из трёх: включить в периметр / исключить / исключить, но сообщить заказчику.
Обоснование — 2–4 предложения со ссылкой на конкретные данные из артефактов. Утверждения без опоры на факт не засчитываются.
Что включаете — если вердикт «включить»: домен, IP-адрес или оба

Кейс 1. gidromashservis.ru — домен

Что это такое — вероятнее всего компания выкупила созвучное доменное имя, чтобы редиректить юзеров на основной домен при тайпскваттинге/для избежания фишинговых подделок сайта. это подтверждают идентичные ИНН
Вердикт — включить
Обоснование — идентичные ИНН, как основной домен указан оригинальный gidromash-service.ru
Что включаете — домен

Кейс 2. 95.213.184.77 — IP-адрес

Что это такое — айпи поддомена, содержащий личные кабинеты пользователей
Вердикт — включить
Обоснование — несмотря на то что поиск по интернет-сервисам отдал 63 записи, все хосты принадлежат гидромашу. вероятнее всего это их IP адрес, а не общий хостинг
Что включаете — IP-адрес

Кейс 3. backup-old.gidromash-service.ru — поддомен

Что это такое — вероятнее всего теневое айти с бэкапами
Вердикт — исключить и сообщить заказчику
Обоснование — очень вероятно, что там содержатся конфеденциальные файлы, вендору следует запретить доступ к домену из внешней сети

Кейс 4. gidromash-nasos.ru

Что это такое — исторический домен сайта из веб-архива
Вердикт — исключить
Обоснование — по выводу утилит можно заключить, что домен больше не поддерживается и доступен только из веб-архива, скорее всего, предыдущее имя основного домена